

# SIMATS ENGINEERING

## ASSESSMENT TOOL 2

**COURSE NAME:** Ethical Hacking

**COURSE CODE:** ITA14

---

### **COURSE OUTCOME COVERED**

**CO3:** Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BT4)

*Assessment Tool Weightage: 30%*

Duration: 90 min

Total Marks: 50

---

### **Code of Conduct:**

I V. Bala Siva Prasad Reddy(192424316) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.  
I understand that any violation of academic integrity rules will result in disciplinary action.

### **Signature of the student:**

*V. Bala Siva Prasad Reddy*

# Port Scanning Challenge

1. Using Nmap, perform a security assessment on the server 192.168.1.20. Identify all open ports and running services. Analyze the purpose of each discovered service and recommend security measures to reduce the attack surface of the system.

## Security Assessment of Server Using Nmap

**Target IP:** 192.168.1.20

**Tool Used:** Nmap 7.99

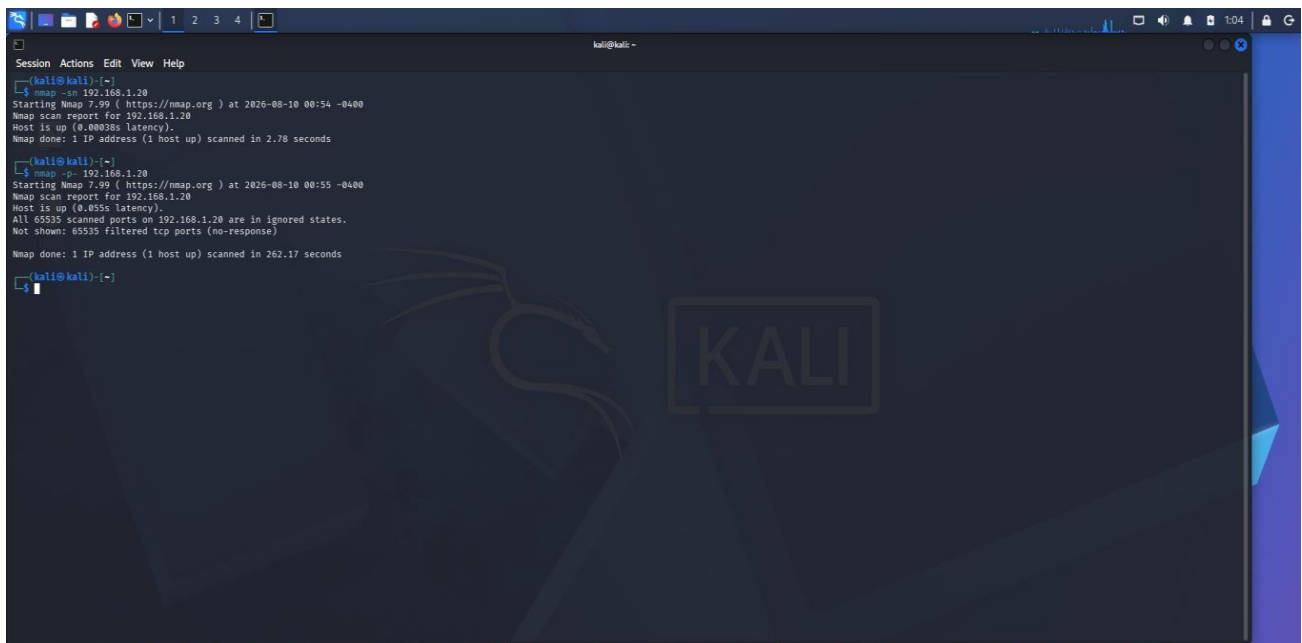
### Objective :

To perform a security assessment of the server 192.168.1.20 using Nmap, identify the open ports and running services, analyze the purpose and security risks of each service, and recommend suitable security measures to reduce the attack surface.

### Host Discovery , Scanning All TCP Ports :

**Command 1 :** nmap -sn 192.168.1.20

**Command 2 :** nmap -p- 192.168.1.20

A screenshot of a Kali Linux terminal window. The terminal shows two Nmap commands and their outputs. The first command is 'nmap -sn 192.168.1.20', which performs a host discovery scan. The output indicates that the host is up and that 1 IP address was scanned in 2.78 seconds. The second command is 'nmap -p- 192.168.1.20', which performs a full TCP port scan on all 65,535 ports. The output shows that all 65,535 scanned ports are in a filtered state, and no open TCP ports were identified. The terminal background features a Kali Linux logo and the word 'KALI' in large letters.

### Result :

The Nmap host discovery scan confirmed that the target server 192.168.1.20 is active and reachable on the network. A full TCP port scan was performed on all 65,535 TCP ports of the target server. All 65,535 ports were reported as filtered, and no open TCP ports were identified.

## Service and Version Detection

**Command 3 :** nmap -sV 192.168.1.20

```
kali@kali:~$ nmap -sV 192.168.1.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-10 01:11 -0400
Nmap scan report for 192.168.1.20
Host is up (0.00056s latency).
All 1000 scanned ports on 192.168.1.20 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.78 seconds

kali@kali:~$ sudo nmap -sU --top-ports 100 192.168.1.20
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-10 01:13 -0400
Nmap scan report for 192.168.1.20
Host is up (0.0022s latency).
Not shown: 95 open/filtered udp ports (no-response)
PORT      STATE SERVICE
135/udp    filtered msrpc
445/udp    filtered microsoft-ds
1023/udp   filtered unknown
5060/udp   filtered sip
5353/udp   filtered zeroconf
Nmap done: 1 IP address (1 host up) scanned in 37.14 seconds

kali@kali:~$ sudo nmap -Pn -sS -p 1-1000 192.168.1.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-10 01:15 -0400
Stats: 0:13:28 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 17.80% done; ETC: 02:30 (1:02:02 remaining)

kali@kali:~$ nmap -sV 192.168.1.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-10 01:37 -0400
Nmap scan report for 192.168.1.20
Host is up (0.00051s latency).
All 1000 scanned ports on 192.168.1.20 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.57 seconds

kali@kali:~$
```

### Result:

Nmap service and version detection was performed on the target. The scan checked the 1,000 most commonly used TCP ports. All 1,000 ports were reported as filtered, and no accessible TCP services or service versions were identified.

### UDP Scan

**Command 4 :** nmap -sV 192.168.1.20

```
kali@kali:~$ sudo nmap -sU --top-ports 100 192.168.1.20
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-10 01:42 -0400
Nmap scan report for 192.168.1.20
Host is up (0.0014s latency).
Not shown: 96 open/filtered udp ports (no-response)
PORT      STATE SERVICE
17/udp     filtered quotd
443/udp     filtered microsoft-ds
1023/udp    filtered unknown
4444/udp    filtered keb524
Nmap done: 1 IP address (1 host up) scanned in 5.92 seconds

kali@kali:~$
```

### Result:

A UDP scan was performed against the 100 most commonly used UDP ports. Nmap reported five ports as filtered: 135, 445, 1023, 5060, and 5353. The remaining 95 ports were reported as open\ filtered because no response was received. No UDP port was confirmed as open.

## Security Analysis :

- **No confirmed open TCP ports :** The full TCP scan did not identify any confirmed open TCP ports. All 65,535 TCP ports were reported as filtered.
- **No confirmed open UDP ports :** The UDP scan did not identify any confirmed open UDP ports. Several UDP ports were reported as filtered or open\filtered.
- **Network filtering :** The consistent filtered results suggest that a firewall or network-level packet-filtering mechanism is preventing direct access to the target's ports.

## Security Recommendations :

- Disable unnecessary services so that unused network services are not exposed.
- Use firewall rules to allow only required ports and trusted sources.
- Restrict administrative access to authorized users and networks.
- Keep operating systems and services updated with the latest security patches.
- Use strong authentication for administrative services.
- Monitor firewall and server logs for suspicious connection attempts.
- Regularly perform Nmap scans to identify newly exposed ports.
- Apply the principle of least privilege to users and services.

## Attack Surface Reduction :

The attack surface of the server can be reduced by exposing only the network services that are necessary for its intended function. Unnecessary services should be disabled, and firewall rules should restrict access to required services. Administrative services should be accessible only to authorized users or trusted networks. Regular security scans should also be performed to detect unintended changes in the server's exposed services.

2. Using Nikto, assess the web server hosted on 192.168.1.30. Identify potential web server misconfigurations, outdated components, or exposed files and directories. Discuss the security risks associated with your findings and suggest appropriate mitigation strategies.

## **Nikto Web Server Security Assessment**

**Target:** 192.168.1.30

**Tool:** Nikto

### **Objective :**

The objective of this assessment is to analyze the web server hosted on **192.168.1.30** using the Nikto web server vulnerability scanner. The assessment focuses on identifying potential web server misconfigurations, outdated software components, exposed files and directories, and other security weaknesses.

### **Lab Environment**

**Scanning machine:** Kali Linux

**Target:** Metasploitable 2

**Tool:** Nikto

**Kali IP:** 192.168.56.101

### **Initial Target Verification**

**Command 1 :** ping -c 4 192.168.1.30

- Then we checked the HTTP/HTTPS ports : nmap -p 80,443 -sV 192.168.1.30
- Ports 80 and 443 were shown as filtered, so the web server could not be identified.
- The lab target was Metasploitable 2, we checked its IP using : ifconfig
- Metasploitable initially had 192.168.56.102.

### **Resolving the IP Conflict**

We checked the Host-Only network using : sudo arp-scan --interface=eth1 192.168.56.0/24

**Result :** The scan showed that two devices were using 192.168.56.102, causing an IP conflict.

```

No mail.
msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.56.103 netmask 255.255.255.0 up
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:73:fb:10
          inet addr:192.168.56.103  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe73:fb10/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:519 errors:0 dropped:0 overruns:0 frame:0
          TX packets:77 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:34902 (34.0 KB)  TX bytes:10419 (10.1 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:118 errors:0 dropped:0 overruns:0 frame:0
          TX packets:118 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:31841 (31.0 KB)  TX bytes:31841 (31.0 KB)

msfadmin@metasploitable:~$ _

```

```

kali@kali ~$ ping -c 4 192.168.56.103
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data.
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=2.70 ms
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=1.65 ms
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=2.39 ms
64 bytes from 192.168.56.103: icmp_seq=4 ttl=64 time=3.77 ms

--- 192.168.56.103 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3093ms
rtt min/avg/max/mdev = 1.652/2.628/3.772/0.762 ms

kali@kali ~$ nmap -p 80 -sV 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-10 23:39 EDT
Nmap scan report for 192.168.56.103
Host is up (0.020s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 7.69 seconds

kali@kali ~$ nikto -h http://192.168.56.103
- Nikto v2.5.0

+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 80
+ Start Time: 2026-08-10 23:39:49 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis-sing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,ht
+ /exchange.xforce.idmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross\_Site\_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /%PMPB85F2A0-3C92-11D3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /%PMPB85F2A0-3C92-11D3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /%PMPB85F2A0-3C92-11D3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /%PMPB85F2A0-3C92-11D3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184

```

## Web Server Identification

Nmap was used to identify the web service:

**Command 2 :** `nmap -p 80 -sV 192.168.56.103`

**Result :** 80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2). Thus, the target was running Apache HTTP Server 2.2.8.

# Nikto Scan :

**Command 3 :** nikto -h http://192.168.56.103

Nikto completed the scan and reported 27 findings.

```
Session Actions Edit View Help
nmap/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
MAC Address: 08:00:27:73:F8:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.69 seconds

kali@kali:~$ nikto -h http://192.168.56.103
- Nikto v2.5.0

+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 80
+ Start Time: 2026-08-10 23:39:49 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis-sing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /: PHP88B5F2A0-3C92-1d32-A3A9-4C7B88C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /: PHP95968F36-0A28-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /: PHP95968F34-0A28-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /: PHP95968F35-0A28-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/changelog: Server may leak inodes via Elgg, header found with file /phpMyAdmin/Changelog, inode: 92462, size: 48540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/changelog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /php-config.php: php-config.php file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2026-08-10 23:41:41 (GMT-4) (112 seconds)

+ 1 host(s) tested

kali@kali:~$
```

## Major Findings

- Outdated Apache 2.2.8
- Outdated PHP 5.2.4
- Missing X-Frame-Options
- Missing X-Content-Type-Options
- Apache MultiViews enabled
- HTTP TRACE method enabled
- /phpinfo.php exposed
- Directory indexing enabled for /doc/, /test/, and /icons/
- /phpMyAdmin/ exposed

## Security Risks

- The outdated Apache and PHP versions may contain known vulnerabilities and increase the possibility of attacks.
- The exposed phpinfo.php can reveal detailed server and PHP configuration information.

- Exposed phpMyAdmin provides access to a database administration interface and should not be publicly accessible without proper restrictions.
- Directory indexing can allow attackers to discover files and resources.
- Missing security headers and enabled HTTP TRACE also increase the server's attack surface.

## **Mitigation Strategies**

- Upgrade Apache and PHP to supported versions.
- Remove unnecessary backup, test, and documentation files.
- Remove or restrict access to phpinfo.php.
- Restrict phpMyAdmin to authorized users/networks.
- Disable directory listing where unnecessary.
- Disable HTTP TRACE.
- Disable MultiViews if not required.
- Configure security headers such as X-Frame-Options and X-Content-Type-Options.
- Regularly patch and scan the web server.

## **Conclusion**

The Nikto assessment successfully identified several security weaknesses in the Metasploitable web server. The major concerns were outdated Apache/PHP versions, exposed phpMyAdmin and configuration-related files, directory indexing, and missing security headers. The assessment demonstrated how Nmap can first identify the web service and Nikto can then perform a more detailed security assessment.



- Using Netcat (nc), investigate the host 192.168.1.40 by connecting to open ports and collecting available service banners. Analyze the information obtained and explain how attackers could use banner information during the reconnaissance phase of an attack.

## Service Banner Enumeration Using Netcat

### Objective

To investigate the target host using Netcat (nc), identify open ports, collect available service banners, and understand how banner information can help attackers during reconnaissance.

### Procedure

1. **Target identification:** The IP 192.168.1.40 given in the question was not reachable, so a local Metasploitable 2 lab machine was used as the authorized target. Its IP address was identified as: 192.168.56.102

2. **Connectivity test :** ping -c 4 192.168.56.102

**Result :** The host responded successfully with 0% packet loss, confirming connectivity between Kali Linux and Metasploitable 2.

3. **Open-port scanning using Netcat :** nc -zv 192.168.56.102 1-1000

| Port | Port name | Port | Port name    |
|------|-----------|------|--------------|
| 21   | FTP       | 80   | HTTP         |
| 22   | SSH       | 111  | SunRPC       |
| 23   | Telnet    | 139  | NetBIOS      |
| 25   | SMTP      | 445  | Microsoft-DS |
| 53   | DNS       | 512  | exec         |

### 4. Banner collection:

- FTP banner was collected using : nc -v 192.168.56.102 21

Result : 220 (vsFTPd 2.3.4)

- SSH banner was collected using : nc -v 192.168.56.102 22

Result : SSH-2.0-OpenSSH\_4.7p1 Debian-8ubuntu

- HTTP was also accessed using : nc -v 192.168.56.102 80

Result : The connection confirmed that the HTTP service was open.

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
└─$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=27.9 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=7.04 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=51.4 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=9.63 ms

--- 192.168.56.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3014ms
rtt min/avg/max/mdev = 7.038/23.993/51.377/17.743 ms

(kali@kali)-[~]
└─$ nc -zv 192.168.56.102 1-1000
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 514 (shell) open
(UNKNOWN) [192.168.56.102] 513 (login) open
(UNKNOWN) [192.168.56.102] 512 (exec) open
(UNKNOWN) [192.168.56.102] 445 (microsoft-ds) open
(UNKNOWN) [192.168.56.102] 139 (netbios-ssn) open
(UNKNOWN) [192.168.56.102] 111 (sunrpc) open
(UNKNOWN) [192.168.56.102] 80 (http) open
(UNKNOWN) [192.168.56.102] 53 (domain) open
(UNKNOWN) [192.168.56.102] 25 (smtp) open
(UNKNOWN) [192.168.56.102] 23 (telnet) open
(UNKNOWN) [192.168.56.102] 22 (ssh) open
(UNKNOWN) [192.168.56.102] 21 (ftp) open

(kali@kali)-[~]
└─$ nc -v 192.168.56.102 21
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 21 (ftp) open
220 (vsFTPd 2.3.4)
^C

(kali@kali)-[~]
└─$ nc -v 192.168.56.102 22
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 22 (ssh) open
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
^C

(kali@kali)-[~]
└─$ nc -v 192.168.56.102 80
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 80 (http) open
GET / HTTP/1.0

HTTP/1.1 200 OK
Date: Tue, 11 Aug 2026 04:59:44 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
```

```
Session f Terminal Emulator
Use the command line
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
^C

(kali@kali)-[~]
└─$ nc -v 192.168.56.102 80
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 80 (http) open
GET / HTTP/1.0

HTTP/1.1 200 OK
Date: Tue, 11 Aug 2026 04:59:44 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Connection: close
Content-type: text/html

<html><head><title>Metasploitable2 - Linux</title></head><body>



Metasploitable2



Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

</pre>
<ul>
<li><a href="/twiki/">TWiki</a></li>
<li><a href="/phpMyAdmin/">phpMyAdmin</a></li>
<li><a href="/mutillidae/">Mutillidae</a></li>
<li><a href="/dwa/">DWA</a></li>
<li><a href="/dav/">WebDAV</a></li>
</ul>
</body>
</html>

(kali@kali)-[~]
└─$ nc -v 192.168.56.102 25
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 25 (smtp) open
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
```

## Analysis

The banners revealed the service names, software products, and versions running on the target. An attacker could use this information during reconnaissance to identify technologies and compare their versions against publicly known vulnerabilities. This can help them select potential attack paths.

## Conclusion

Netcat successfully identified multiple open services and collected FTP and SSH service banners from the Metasploitable 2 host. The exercise demonstrated how exposed service information can provide useful reconnaissance information to attackers. Administrators should keep services updated, disable unnecessary services, restrict access to exposed ports, and minimize unnecessary version disclosure.

4. Using Telnet, examine the server 192.168.1.50 to determine whether remote administration services are accessible. Identify any security concerns related to the discovered services and recommend more secure alternatives where appropriate.

### **Remote Administration Service Assessment Using Telnet**

#### **Objective :**

To examine the Metasploitable server and determine whether remote administration services are accessible using Telnet, identify security concerns, and recommend secure alternatives.

**Scanning machine:** Kali Linux

**Tool :** Telnet

**Target:** Metasploitable 2

**Target IP:** 192.168.56.102

#### **Procedure :**

- Identified the IP address of the Metasploitable machine.
- From Kali Linux, tested the Telnet service : telnet 192.168.56.102 23
- The connection was successful and the Metasploitable login prompt was displayed.
- Tested RDP : telnet 192.168.56.102 3389
- The connection was refused, indicating that RDP was not accessible.

#### **Commands :**

- telnet 192.168.1.50 22
- telnet 192.168.1.50 23
- telnet 192.168.1.50 3389

#### **Results :**

| Port | Service | Result         |
|------|---------|----------------|
| 23   | Telnet  | Accessible     |
| 3389 | RDP     | Not Accessible |

```
Session / Terminal Emulator
Use the command line

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~$ telnet --help
Usage: telnet [OPTION...] [HOST [PORT]]
Login to remote system HOST (optionally, on service port PORT)

General options:
  -4, --ipv4          use only IPv4
  -6, --ipv6          use only IPv6
  -9, --binary        use an 8-bit data transmission
  -a, --login         attempt automatic login
  -b, --bind=ADDRESS  bind to specific local ADDRESS
  -c, --no-rc         do not read the user's .telnetrc file
  -d, --debug         turn on debugging
  -e, --escape=CHAR   use CHAR as an escape character
  -E, --no-escape     use no escape character
  -K, --no-login      do not automatically login to the remote system
  -L, --user=USER     attempt automatic login as USER
  -l, --binary-output use an 8-bit data transmission for output only
  -n, --trace=FILE    record trace information into FILE
  -r, --rlogin        use a user-interface similar to rlogin

Encryption control:
  -x, --encrypt       encrypt the data stream, if possible

Authentication and Kerberos options:
  -k, --realm=REALM   obtain tickets for the remote host in REALM
                        instead of the remote host's realm
  -X, --disable-auth=ATYPE  disable type ATYPE authentication
  -?, --help          give this help list
  -usage              give a short usage message
  -V, --version        print program version

Mandatory or optional arguments to long options are also mandatory or optional
for any corresponding short options.

Report bugs to <bug-inetutils@gnu.org>.

(kali@kali)~$ telnet 192.168.56.102 23
Trying 192.168.56.102...
Connected to 192.168.56.102.
Escape character is '^['.
```

```
Session Actions Edit View Help

-x, --encrypt          encrypt the data stream, if possible

Authentication and Kerberos options:
-k, --realm=REALM      obtain tickets for the remote host in REALM
                        instead of the remote host's realm
-X, --disable-auth=ATYPE  disable type ATYPE authentication
-?, --help            give this help list
-usage                give a short usage message
-V, --version          print program version

Mandatory or optional arguments to long options are also mandatory or optional
for any corresponding short options.

Report bugs to <bug-inetutils@gnu.org>.

(kali@kali)~$ telnet 192.168.56.102 23
Trying 192.168.56.102...
Connected to 192.168.56.102.
Escape character is '^['.
```

metasploitable2

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin  
Password:  
Last login: Tue Aug 11 00:31:04 EDT 2026 on tty1  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/\*/\*copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.

To access official Ubuntu documentation, please visit:  
<http://help.ubuntu.com/>

```
Firefox ESR
Browse the World Wide Web

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~$ telnet 192.168.56.102 22
Trying 192.168.56.102...
Connected to 192.168.56.102.
Escape character is '^['.
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
telnet> quit
Connection closed.

(kali@kali)~$
```

## Security Concerns

- Telnet is insecure because it transmits login credentials and session data without encryption.
- An attacker monitoring the network could potentially capture sensitive information.
- Exposed remote-administration services can increase the risk of unauthorized access.

## Recommendations

- Disable Telnet wherever possible.
- Use SSH (Port 22) for secure, encrypted remote administration.
- Restrict remote-administration services using firewalls and trusted networks.
- Use strong authentication and avoid exposing management services unnecessarily.

## Conclusion

The assessment confirmed that Telnet on port 23 was accessible on the Metasploitable server, while RDP on port 3389 was not accessible. Telnet presents a significant security weakness because it does not provide encrypted communication. SSH is recommended as the safer alternative.

5. Using Netdiscover, perform host discovery on the network segment 192.168.1.1–50. Identify active hosts on the network and analyze how the discovered information could assist an attacker in planning further enumeration or exploitation activities..

## Host Discovery Using Netdiscover

### Objective :

To perform host discovery on the authorized network segment and identify active hosts using Netdiscover.

### Tools Used

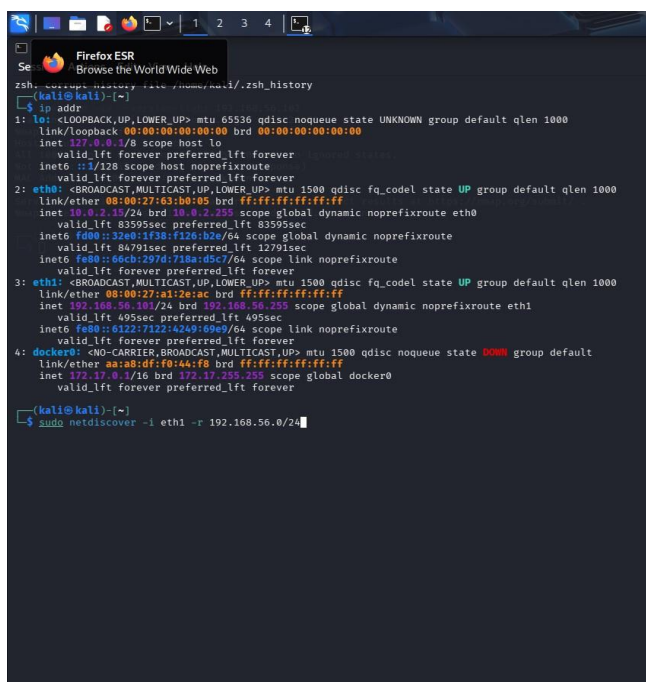
Kali Linux , Netdiscover , VirtualBox

### Procedure

- Checked the available network interfaces using : `ip addr`
- Identified eth1 as the lab interface with IP address 192.168.56.101/24.
- Performed host discovery using : `sudo netdiscover -i eth1 -r 192.168.56.0/24`
- Waited for the scan to finish and recorded the discovered IP addresses, MAC addresses, and vendor information.

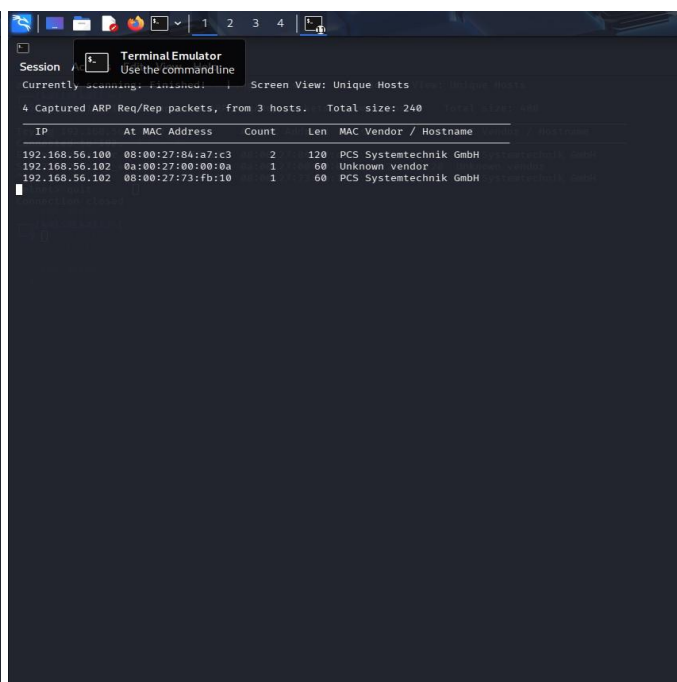
### Commands :

- `ip addr`
- `sudo netdiscover -i eth1 -r 192.168.56.0/24 | tee netdiscover_result.txt`



```
zsh: source ~/.bashrc; task -x -m netdiscover --zsh_history
(kali@kali)~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 10.9.2.15/24 brd 10.9.2.255 scope global dynamic noprefixroute eth0
        valid_lft 83595sec preferred_lft 83595sec
    inet6 fd00::32e0:1f38:f126:b2e/64 scope global dynamic noprefixroute
        valid_lft 84791sec preferred_lft 12701sec
    inet6 fe80::84eb:297d:738a:65c7/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:a152:cac brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth1
        valid_lft 495sec preferred_lft 495sec
    inet6 fe80::6122:7122:a249:80e9/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether aa:a8:df:f0:44:f8 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever

(kali@kali)~$ sudo netdiscover -i eth1 -r 192.168.56.0/24
```



```
Session / Terminal Emulator
Use the command line
Currently scanning... Screen View: Unique Hosts
4 Captured ARP Req/Rep packets, from 3 hosts. Total size: 240

IP           At MAC Address      Count  Len  MAC Vendor / Hostname
-----
192.168.56.100 08:00:27:84:a7:c3    2     120  PCS Systemtechnik GmbH
192.168.56.102 0a:00:27:00:00:0a    1      60  Unknown vendor
192.168.56.102 08:00:27:73:fb:10    1      60  PCS Systemtechnik GmbH
```

## Results :

| IP Address     | MAC Address       | Vendor                 |
|----------------|-------------------|------------------------|
| 192.168.56.100 | 08:00:27:84:a7:c3 | PCS Systemtechnik GmbH |
| 192.168.56.102 | 08:00:27:00:00:0a | Unknown Vendor         |
| 192.168.56.102 | 08:00:27:73:fb:10 | PCS Systemtechnik GmbH |

### Netdiscover reported:

- 4 Captured ARP Req/Rep packets, from 3 hosts.
- The repeated 192.168.56.102 entry represents the same IP appearing with different MAC information in the virtualized lab environment.

## Security Analysis

The discovered IP addresses identify active systems on the network. MAC addresses and vendor information provide additional information about their network interfaces. An attacker could use this information during reconnaissance to identify potential systems for further authorized service and vulnerability enumeration.

## Conclusion

Netdiscover successfully identified active hosts on the lab network and displayed their IP, MAC, and vendor information. The experiment demonstrates how host discovery can provide an initial network map for security assessment.

| <b>Q.No</b> | <b>Identification of Port Scanning Factors(25)</b> | <b>Analysis(25)</b> | <b>Linkage(20)</b> | <b>Application(20)</b> | <b>Clarity(10)</b> | <b>Marks</b> |
|-------------|----------------------------------------------------|---------------------|--------------------|------------------------|--------------------|--------------|
| <b>1</b>    |                                                    |                     |                    |                        |                    |              |
| <b>2</b>    |                                                    |                     |                    |                        |                    |              |
| <b>3</b>    |                                                    |                     |                    |                        |                    |              |
| <b>4</b>    |                                                    |                     |                    |                        |                    |              |
| <b>5</b>    |                                                    |                     |                    |                        |                    |              |

**Signature of Faculty**

**Total Avg :**

**RUBRICS FOR CALCULATION:**

| <b>Criteria</b>                         | <b>Weightage</b> | <b>Level 4 (Exemplary)</b>                                                                      | <b>Level 3 (Proficient)</b>               | <b>Level 2 (Developing)</b>                  | <b>Level 1 (Beginning)</b>                    |
|-----------------------------------------|------------------|-------------------------------------------------------------------------------------------------|-------------------------------------------|----------------------------------------------|-----------------------------------------------|
| Identification of Port Scanning Factors | 25%              | Clearly identifies comprehensive and relevant strengths, weaknesses, opportunities, and threats | Identifies most factors with minor gaps   | Limited or partially relevant identification | Incorrect or incomplete Port Scanning factors |
| Analysis                                | 25%              | Provides deep, insightful analysis of each Port Scanning component with strong reasoning        | Provides good analysis with some depth    | Basic analysis with limited reasoning        | No meaningful analysis provided               |
| Linkage                                 | 20%              | Effectively links Port Scanning elements to derive strong strategic insights and implications   | Shows some linkage with moderate insights | Weak linkage; limited strategic thinking     | No linkage or strategic insight               |
| Application                             | 20%              | Applies Port Scanning analysis effectively to the given case or scenario with clear relevance   | Applies analysis with minor gaps          | Limited application; lacks clarity           | No clear application to context               |
| Clarity                                 | 10%              | Well-structured, clear, and logically presented with proper formatting                          | Generally clear with minor issues         | Some structure but lacks clarity             | Poorly organized and difficult to understand  |